

République du Cameroun
Paix-Travail-Patrie

Ministère de l'Enseignement Supérieur

Université de Garoua

Faculté des Sciences

Division des Affaires Académiques, de la
Scolarité et de la Recherche

Republic of Cameroon
Peace-Work-Fatherland

Ministry of Higher Education

Université of Garoua

Faculté of Science

Division of Academic Affairs, Student's
Admission and Research



UE : ANALYSE FORENSIQUE ET GESTION DES INCIDENTS

TPE: RETOUR D'EXPÉRIENCE ET AMÉLIORATION CONTINUE

N°	Noms et prénoms	Matricule	NIVEAU
1	NAMAWI JEAN YVES	CM-UGa-24FS0784	MASTER II

CHAPITRE 10: RETOUR D'EXPÉRIENCE ET AMÉLIORATION CONTINUE.

Exercice 10.1 — RETEX structuré

1) Contexte et chronologie

L'incident a commencé par un scan de reconnaissance, suivi d'un bruteforce SSH, d'une authentification réussie, puis d'une exécution de script, d'une connexion C2, d'un mouvement latéral SMB vers un serveur ERP, et enfin d'un effacement de journaux sur la cible.

La chronologie montre une chaîne cohérente d'attaque avec progression du point d'entrée vers l'impact et la dissimulation.

2) Impact

L'impact principal est la compromission d'un serveur applicatif puis la propagation vers un second hôte, avec effacement de journaux pour masquer les traces.

Sur le plan opérationnel, cela implique une perte de confiance dans l'intégrité des journaux, un risque de fuite de données et une interruption potentielle de service.

3) Causes profondes

La cause racine décrite dans le cours est l'**absence de gouvernance sécurité formelle**, illustrée par une PSSI obsolète et l'absence de RSSI à temps plein.

En cause contributive, le compte backup avait un mot de passe faible et la politique de mots de passe ne couvrait pas correctement les comptes de service.

4) Analyse avec les 5 Pourquoi

1. Pourquoi l'attaquant a-t-il réussi l'accès initial ? Parce que le compte backup avait un mot de passe faible.
2. Pourquoi ce mot de passe était faible ? Parce que la politique ne couvrait pas les comptes de service.
3. Pourquoi la politique ne les couvrait-elle pas ? Parce que la PSSI n'avait pas été mise à jour depuis 3 ans.
4. Pourquoi n'avait-elle pas été revue ? Parce qu'aucun processus de revue annuelle n'était formalisé.^[1]
5. Pourquoi aucun processus n'existait-il ? Parce qu'il n'y avait pas de RSSI à temps plein pour porter cette gouvernance.

5) Analyse de la détection et de la réponse

Le SIEM a détecté certaines étapes, mais trop tard pour empêcher l'authentification réussie et la phase de propagation.

Les sources manquantes ou insuffisantes concernaient probablement une couverture plus large des logs d'authentification, de l'activité hôte et des règles de corrélation sur les mouvements latéraux.

6) Recommandations priorisées

- **Priorité 1** : imposer une politique de mots de passe et de comptes de service robuste, avec rotation et secrets dédiés.
- **Priorité 2** : activer des règles SIEM dédiées au brute force SSH, au C2 et au mouvement latéral SMB.
- **Priorité 3** : déployer ou renforcer la collecte centralisée des logs avec intégrité et rétention suffisante.
- **Priorité 4** : mettre en place un HIDS/FIM sur les serveurs critiques pour détecter les effacements de journaux et modifications locales.
- **Priorité 5** : formaliser la revue annuelle de la PSSI et des comptes sensibles avec un responsable identifié.
- **Priorité 6** : conduire des exercices Purple Team réguliers pour tester les angles morts de couverture.

Exercice. 10.2 — Tableau de couverture ATT&CK

Technique MITRE	Source de log requise	Règle SIEM existante ?	Action si inexistante
T1595 Reconnaissance / scan de ports	pfSense, logs firewall, éventuellement Suricata	Oui, détection de scan SYN déjà illustrée	Créer une corrélation de ports multiples par source avec seuil temporel
T1110.001 Password Spraying / bruteforce SSH	auth.log, SIEM d'authentification	Oui, règle SIEM de bruteforce SSH mentionnée	Ajouter seuil par IP, par utilisateur et fenêtre glissante
T1059.004 Shell script / exécution de script	Sysmon EID 1, journaux hôte, EDR	Partiel, observé via Sysmon	Créer règle sur exécution de scripts depuis répertoires non standards
T1071.001 C2 via protocole web	Sysmon EID 3, proxy, firewall, EDR	Oui, connexion sortante déjà corrélée	Ajouter détection d'URL/domaines anormaux et périodicité beacon

T1021.002 SMB / mouvement latéral	Security logs Windows, EID 4624, 4776, 5140 si disponible	Oui, mentionné dans le tableau d'incident	Ajouter corrélation login anormal + accès SMB inter-serveurs
T1070.001 Effacement de journaux	Windows EID 1102, EID 104, FIM Linux/Wazuh	Oui, déjà listé comme IoC critique	Déclencher alerte critique sur suppression/vidage de logs
T1005 Collecte de données locales	Logs applicatifs, MySQL, audit DB, proxy	Non explicitement détaillée dans l'incident	Créer règles sur volumes d'accès inhabituels et requêtes massives

Exercice 10.3 — Scénario Purple Team

Objectif

Tester trois angles morts de détection en reproduisant des techniques proches de celles de l'incident, mais en les déplaçant vers la validation défensive et la mesure de couverture ATT&CK. L'objectif n'est pas de "faire une attaque", mais de vérifier que le SOC voit bien les comportements et déclenche des alertes exploitables.

Technique 1 : effacement de journaux

- **Simulation** : sur une machine de test, lancer une action d'effacement ou de troncature contrôlée d'un journal système pour imiter T1070.001.
- **Source attendue** : Windows Security / System, EID 1102 ou 104, ou alerte FIM si Linux.
- **Règle SIEM à créer** : alerte critique dès qu'un événement d'effacement de journal est observé sur un hôte de production.

Technique 2 : mouvement latéral SMB

- **Simulation** : ouvrir une session SMB d'un serveur compromis de test vers un second serveur pour vérifier la visibilité des connexions et authentifications latérales T1021.002.
- **Source attendue** : Security log Windows, authentifications réseau, corrélation hôte à hôte.
- **Règle SIEM à créer** : corréler une authentification inhabituelle suivie d'un accès SMB entre deux serveurs qui n'ont pas d'interaction normale.

Technique 3 : C2 discret

- **Simulation** : générer un trafic périodique sortant vers un domaine de test, avec intervalle régulier, pour tester T1071.001.
- **Source attendue** : Sysmon EID 3, proxy, NetFlow, firewall.
- **Règle SIEM à créer** : détecter la répétition régulière de connexions sortantes vers une destination peu commune, avec volume faible et intervalle stable.

Critères de réussite

- L'alerte doit être générée pendant l'exercice, pas après coup.
- Le temps de détection doit être mesuré et comparé à la cible SOC.
- La règle créée doit être documentée dans le registre de couverture ATT&CK avec statut "détecté" ou "partiellement détecté".